Leistungsbeschreibung Penetrationstest software:112

Anfrage für ein Angebot · IC&P Consultants e.U. · Stand 23. September 2026

Ausgangslage

software:112 ist eine mandantenfähige Branchensoftware für Weinbaubetriebe (Kellerbuch, Weingarten, Verkauf, CRM, Einnahmen-Ausgaben-Rechnung). Mehrere Betriebe teilen sich eine Anwendung und eine Datenbank; die Trennung der Betriebe ist deshalb die wichtigste Sicherheitseigenschaft. Betreiber ist IC&P Consultants e.U., die Software ist ein Produkt von hohenstein consulting solutions.

Wir suchen einen externen, unabhängigen Penetrationstest als Nachweis für Kunden und als Prüfung unserer eigenen Sicherheitsmaßnahmen (Welle 1–5, September 2026). Der Test soll vor der Aufnahme von mehr als zehn produktiven Betrieben stattfinden.

Technischer Aufbau

Baustein	Technik	Standort
Webanwendung und Serverfunktionen	Next.js 16 auf Vercel (Pro), Fluid Compute	EU – Frankfurt (fra1)
Datenbank, Anmeldung, Dateispeicher	Supabase (Pro): PostgreSQL mit Row Level Security, PostgREST, Supabase Auth mit TOTP-Zwei-Faktor	EU – Irland
Anbindungen	Microsoft 365 (OAuth, Graph-Webhooks), Stripe (Abo, Webhook), Brevo (E-Mail/Newsletter), SumUp (Kartenzahlung), Anthropic (KI-Abfragen)	extern
Öffentliche Seiten	Anmeldung, Registrierung, Newsletter-Anmeldung je Betrieb, Barrierefreiheit, security.txt	–

Ziele des Tests

Der Test soll vor allem beantworten, ob ein Benutzer eines Betriebs auf Daten eines anderen Betriebs zugreifen oder sie verändern kann, ob die Rollen innerhalb eines Betriebs (Super-Admin, Betriebs-Manager, Mitarbeiter mit Modulrechten, Leser) wirksam durchgesetzt werden, und ob ein Angreifer ohne Konto Zugang zu Daten, Konten oder Zugangsdaten Dritter bekommen kann.

Umfang

Nr.	Bereich	Schwerpunkt
T1	Mandantentrennung	Zugriff auf fremde Betriebe über Oberfläche, Server-Aktionen, API-Routen und direkt über die Supabase-REST-Schnittstelle mit dem öffentlichen Schlüssel
T2	Rollen und Rechte	Rechteausweitung innerhalb eines Betriebs (Leser → Mitarbeiter → Betriebs-Manager), Modulrechte, Administrationsbereiche
T3	Anmeldung und Sitzung	Passwortregeln, Passwort-Reset, Einladungslinks, Zwei-Faktor-Pflicht und deren Umgehung, Sitzungsablauf
T4	Öffentliche Formulare	Registrierung, Newsletter-Anmeldung/-Bestätigung/-Abmeldung, Missbrauch zum Massenversand, Drosselung
T5	Anbindungen	Microsoft-365-OAuth (State, Rückkanal), Graph-Webhook, Stripe-Webhook, SumUp-Webhook, Cron-Endpunkte
T6	Webanwendung allgemein	OWASP Top 10 / ASVS Stufe 2: Injection, XSS, CSRF bei Server-Aktionen, SSRF (Bildoptimierung, Logo-URLs), Datei-Upload, Sicherheits-Header und CSP
T7	Gespeicherte Geheimnisse	Schutz der verschlüsselt gespeicherten Zugangsdaten (E-Mail, Microsoft 365, Brevo, SumUp), keine Preisgabe an den Browser
T8	Datenbankfunktionen	SECURITY-DEFINER-Funktionen über die REST-Schnittstelle, RLS-Lücken

Nicht im Umfang

Angriffe auf die Infrastruktur von Vercel, Supabase, Microsoft, Stripe oder Brevo selbst; Last- und Überlastungstests (DoS/DDoS, massenhafte Anfragen); Social Engineering und Phishing; physische Tests; Microsoft-365-Umgebungen der Kunden. Die Richtlinien der Plattformen sind einzuhalten: Vercel erlaubt Pro-Kunden nicht-volumetrische Tests ohne Voranmeldung, Supabase erlaubt Tests am eigenen Projekt ohne Voranmeldung und verlangt, Schwachstellen in Supabase-Produkten binnen 24 Stunden an Supabase zu melden.

Testart und Bereitstellung

Grey-Box-Test auf der Produktionsumgebung mit zwei eigens angelegten Testbetrieben (keine Kundendaten). Wir stellen je Testbetrieb ein Konto pro Rolle bereit, dazu Architekturübersicht, Rollenkonzept und auf Wunsch Einblick in den Quellcode (Code-Review optional als eigene Position). Die IP-Adressen des Testers werden in der Vercel-Firewall freigeschaltet. Kundendaten dürfen nicht abgerufen, verändert oder gespeichert werden; wird ein Zugriff auf fremde Daten möglich, genügt der Nachweis mit den Testbetrieben.

Erwartete Ergebnisse

Ein Bericht auf Deutsch mit Zusammenfassung für die Geschäftsführung, allen Befunden mit Einstufung nach CVSS 3.1, Nachvollziehbarkeit (Schritte, Anfragen), Empfehlung je Befund, dazu ein Nachtest der behobenen Befunde innerhalb von drei Monaten und eine kurze Bestätigung über den durchgeführten Test zur Weitergabe an Kunden.

Rahmen

Zeitraum: nach Absprache, bevorzugt November 2026 bis Jänner 2027. Kritische Befunde sind sofort telefonisch und an security@icp-consultants.at zu melden. Geheimhaltung und Umgang mit Testdaten nach gesondertem Vertrag. Bitte im Angebot angeben: Aufwand in Personentagen je Bereich T1–T8, Tagessatz, Qualifikation der Tester (z. B. OSCP, OSWE), Referenzen mit mandantenfähigen Webanwendungen, Nachtest, frühester Beginn.

Ansprechpartner

IC&P Consultants e.U., security@icp-consultants.at